

## MATRIZ DE EVALUACIÓN PRAGMATIC COMPLETA

### Calificación Exhaustiva de Métricas CAsPeA contra 9 Criterios de Calidad

**Versión:** 2.1

**Propósito:** Validar que cada métrica propuesta es prácticamente útil, no solo teóricamente interesante

**Escala:** 1-4 (Deficiente | Aceptable | Bueno | Excelente)

### DEFINICIONES DE CRITERIOS PRAGMATIC

| Criterio             | Definición                                  | Aplicación a CAsPeA                       |
|----------------------|---------------------------------------------|-------------------------------------------|
| <b>Predictivo</b>    | Métrica correlaciona con outcome deseado    | ¿Mayor CAsPeA → mejor detección?          |
| <b>Relevante</b>     | Proporciona información útil a stakeholders | ¿Le importa al CFO, CISO, Regulador?      |
| <b>Accionable</b>    | Datos que pueden influenciarse directamente | ¿CISO puede mejorar esto?                 |
| <b>Genuino</b>       | Información real, no ambigua, verificable   | ¿Datos de nómina, logs, auditoría?        |
| <b>Significativo</b> | Impacto material en decisiones              | ¿Cambiaría presupuesto si cambia métrica? |
| <b>Preciso</b>       | Medida confiable, errores $< \pm 10\%$      | ¿Margen error aceptable?                  |
| <b>Oportuno</b>      | Disponible en tiempo para acción            | ¿Trimestral? ¿Mensual? ¿Real-time?        |
| <b>Independiente</b> | No correlaciona spuriamente con otras       | ¿MTTD y MTTR miden cosas diferentes?      |
| <b>Rentable</b>      | Bajo coste recopilación vs valor obtenido   | ¿1 FTE para recopilar = justificado?      |

## MATRIZ DE EVALUACIÓN: TODAS LAS MÉTRICAS CAsPeA

### GRUPO 1: MÉTRICAS DE CARACTERIZACIÓN ORGANIZACIONAL

#### M1.1: Sector Industrial de la Organización

**Definición:** Clasificación sectorial según CNAE/NIS2 (Financiero, Sanitario, Energía, Transporte, etc.)

| Criterio PRAGMATIC | Calificación     | Evidencia                     | Comentario                                   |
|--------------------|------------------|-------------------------------|----------------------------------------------|
| Predictivo         | 2/4 (Aceptable)  | Débil correlación con madurez | Contexto relevante pero no predictor directo |
| Relevante          | 4/4 (Excelente)  | Crítico para normalización    | Determina si NIS2/DORA/ENS aplica            |
| Accionable         | 1/4 (Deficiente) | No controlable                | No puede cambiarse (inmutable)               |
| Genuino            | 4/4 (Excelente)  | Registro oficial AEAT         | Verificable sin ambigüedad                   |
| Significativo      | 4/4 (Excelente)  | Define regulación aplicable   | Multas diferentes por sector                 |
| Preciso            | 4/4 (Excelente)  | Clasificación binaria         | 0% error                                     |
| Oportuno           | 4/4 (Excelente)  | Disponible inmediato          | Constante organizacional                     |
| Independiente      | 4/4 (Excelente)  | Ortogonal a otras métricas    | No covaría                                   |
| Rentable           | 4/4 (Excelente)  | Cero coste                    | Datos públicos/internos                      |
| MEDIA              | 3.3/4            |                               | BUENO                                        |

### M1.2: Tamaño Organizacional (Empleados)

**Definición:** Total de empleados en nómina, criterio de proporcionalidad regulatoria

| Criterio PRAGMATIC | Calificación     | Evidencia                            |
|--------------------|------------------|--------------------------------------|
| Predictivo         | 3/4 (Bueno)      | Correlaciona con complejidad IT      |
| Relevante          | 4/4 (Excelente)  | Determina escala requerimientos NIS2 |
| Accionable         | 1/4 (Deficiente) | Cambiar plantilla ≠ meta seguridad   |
| Genuino            | 4/4 (Excelente)  | Datos nómina verificables            |
| Significativo      | 3/4 (Bueno)      | Afecta presupuesto proporcional      |
| Preciso            | 4/4 (Excelente)  | Número exacto                        |
| Oportuno           | 4/4 (Excelente)  | Conocido anualmente                  |
| Independiente      | 4/4 (Excelente)  | Ortogonal                            |
| Rentable           | 4/4 (Excelente)  | Cero coste                           |
| MEDIA              | 3.4/4            | BUENO                                |

## GRUPO 2: MÉTRICAS DE GESTIÓN DE VULNERABILIDADES

### M2.1: Frecuencia de Escaneo de Vulnerabilidades

**Definición:** Periodicidad (Mensual=1, Semanal=2, Diario=3, Continuo=4) de escaneos automáticos

| Criterio PRAGMATIC | Calificación    | Evidencia                                              |
|--------------------|-----------------|--------------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | Fuerte correlación: escaneo continuo → mayor cobertura |
| Relevante          | 4/4 (Excelente) | NIS2 Anexo III "evaluaciones periódicas"               |
| Accionable         | 4/4 (Excelente) | CISO configura cadencia (bajo coste)                   |
| Genuino            | 4/4 (Excelente) | Logs de SIEM documentan                                |
| Significativo      | 4/4 (Excelente) | Cumplimiento regulatorio depende                       |
| Preciso            | 3/4 (Bueno)     | Definición clara pero depende de autodeclaración       |
| Oportuno           | 4/4 (Excelente) | Real-time (de logs)                                    |
| Independiente      | 3/4 (Bueno)     | Algo correlacionado con presupuesto                    |
| Rentable           | 4/4 (Excelente) | Solo requiere revisión logs                            |
| MEDIA              | 3.7/4           | EXCELENTE                                              |

### M2.2: Cobertura de Escaneo (% Infraestructura)

**Definición:** Porcentaje de infraestructura IT sometida a escaneo (Redes, Servidores, Endpoints, Cloud, OT)

| Criterio PRAGMATIC | Calificación    | Evidencia                                               |
|--------------------|-----------------|---------------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | Cobertura >80% → detección exponencial mejora           |
| Relevante          | 4/4 (Excelente) | NIS2 exige cobertura integral                           |
| Accionable         | 3/4 (Bueno)     | CISO puede expandir (requiere presupuesto + tiempo)     |
| Genuino            | 2/4 (Aceptable) | Requiere auditoría técnica (subjetivo si autodeclarado) |
| Significativo      | 4/4 (Excelente) | Gaps críticos = riesgo material                         |
| Preciso            | 2/4 (Aceptable) | Cálculo % depende de "qué contar" como activos          |
| Oportuno           | 3/4 (Bueno)     | Semestral (requiere auditoría)                          |
| Independiente      | 3/4 (Bueno)     | Correlaciona con tamaño org                             |
| Rentable           | 2/4 (Aceptable) | Auditoría externa costosa                               |
| MEDIA              | 3.1/4           | BUENO                                                   |

### M2.3: MTTR de Vulnerabilidades Críticas (Days)

**Definición:** Media días entre identificación de vulnerabilidad crítica y validación de remediación

| Criterio PRAGMATIC | Calificación    | Evidencia                                       |
|--------------------|-----------------|-------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | MTTR <30d → 80% menos breaches por vuln antigua |
| Relevante          | 4/4 (Excelente) | KPI central NIS2, NIST, DORA                    |
| Accionable         | 4/4 (Excelente) | Equipo IT puede automatizar patches             |
| Genuino            | 4/4 (Excelente) | Logs de vuln tracking system (Qualys, Nessus)   |
| Significativo      | 4/4 (Excelente) | Brecha >60d = exposición crítica                |
| Preciso            | 3/4 (Bueno)     | ±1 día (depende de cómo contar inicios)         |
| Oportuno           | 4/4 (Excelente) | Real-time (del sistema)                         |
| Independiente      | 4/4 (Excelente) | No covarría spuriamente                         |
| Rentable           | 4/4 (Excelente) | Datos automáticos (herramientas existentes)     |
| MEDIA              | 3.8/4           | EXCELENTE                                       |

## GRUPO 3: MÉTRICAS DE PRUEBAS DE PENETRACIÓN

### M3.1: Frecuencia de Pentesting Anual

**Definición:** Número de pentesting reales ejecutados/año (1=Anual, 2=Semestral, 3=Trimestral, 4=Continuo)

| Criterio PRAGMATIC | Calificación    | Evidencia                                                  |
|--------------------|-----------------|------------------------------------------------------------|
| Predictivo         | 3/4 (Bueno)     | Mayor frecuencia → hallazgos reducen (pero efecto plateau) |
| Relevante          | 4/4 (Excelente) | NIS2 exige "testing periódico"                             |
| Accionable         | 3/4 (Bueno)     | CISO contrata (depende presupuesto, €50-150K/test)         |
| Genuino            | 4/4 (Excelente) | Reportes de pentesting auditables                          |
| Significativo      | 4/4 (Excelente) | Determina descubrimiento de hallazgos                      |
| Preciso            | 4/4 (Excelente) | Número exacto de pentests                                  |
| Oportuno           | 2/4 (Aceptable) | Datos disponibles con lag (informe post-test)              |
| Independiente      | 3/4 (Bueno)     | Algo correlaciona con presupuesto                          |
| Rentable           | 2/4 (Aceptable) | Coste alto (€50-150K por pentest)                          |
| MEDIA              | 3.2/4           | BUENO                                                      |

#### GRUPO 4: MÉTRICAS DE SIEM Y DETECCIÓN

##### M4.1: MTTD (Mean Time To Detect)

**Definición:** Tiempo promedio (minutos) desde evento/exploit hasta alerta en SIEM

| Criterio PRAGMATIC | Calificación    | Evidencia                                      |
|--------------------|-----------------|------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | MTTD <60 min → Contención antes dwell >4h      |
| Relevante          | 4/4 (Excelente) | KPI crítico industria (MTTD/MTTR)              |
| Accionable         | 3/4 (Bueno)     | CISO puede mejorar (reglas, ML, threat intel)  |
| Genuino            | 3/4 (Bueno)     | Logs SIEM, pero depende definición "evento"    |
| Significativo      | 4/4 (Excelente) | Impacto directo en losses (dwell time = coste) |
| Preciso            | 3/4 (Bueno)     | ±5 min (depende timestamp sincronización)      |
| Oportuno           | 4/4 (Excelente) | Real-time (dashboards SIEM)                    |
| Independiente      | 4/4 (Excelente) | Ortogonal MTTR                                 |
| Rentable           | 4/4 (Excelente) | Datos SIEM ya recopilados                      |
| MEDIA              | 3.6/4           | EXCELENTE                                      |

#### M4.2: MTTR (Mean Time To Respond)

**Definición:** Tiempo promedio (minutos) desde alerta validada hasta contención/aislamiento

| Criterio PRAGMATIC | Calificación    | Evidencia                                                    |
|--------------------|-----------------|--------------------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | MTTR <240 min – Lateral movement bloqueado                   |
| Relevante          | 4/4 (Excelente) | Métrica clave de responsiveness                              |
| Accionable         | 4/4 (Excelente) | Equipo respuesta puede optimizar (playbooks, automatización) |
| Genuino            | 2/4 (Aceptable) | Depende de definición "contención" (subjetivo)               |
| Significativo      | 4/4 (Excelente) | Dwell time = coste exponencial                               |
| Preciso            | 2/4 (Aceptable) | ±30 min (múltiples pasos, falta sincronización)              |
| Oportuno           | 3/4 (Bueno)     | Trimestral (análisis post-incidente)                         |
| Independiente      | 4/4 (Excelente) | Ortogonal MTTD                                               |
| Rentable           | 3/4 (Bueno)     | Requiere análisis tickets (1 FTE/trimestre)                  |
| MEDIA              | 3.3/4           | BUENO                                                        |

#### GRUPO 5: MÉTRICAS DE CAPACITACIÓN

##### M5.1: Tasa de Reporte de Phishing

**Definición:** % empleados que reportan phishing simulado en <15 minutos vs total clics

| Criterio PRAGMATIC | Calificación    | Evidencia                                            |
|--------------------|-----------------|------------------------------------------------------|
| Predictivo         | 4/4 (Excelente) | Report rate >25% – 60% reducción incidentes phishing |
| Relevante          | 4/4 (Excelente) | Concienciación más efectiva métrica                  |
| Accionable         | 4/4 (Excelente) | Equipo capacitación optimiza programa                |
| Genuino            | 4/4 (Excelente) | Datos de plataforma phishing (KnowBe4, Gophish)      |
| Significativo      | 4/4 (Excelente) | Determina susceptibilidad a social engineering       |
| Preciso            | 4/4 (Excelente) | ±1% (datos automáticos)                              |
| Oportuno           | 4/4 (Excelente) | Real-time (post-campaña)                             |
| Independiente      | 4/4 (Excelente) | Ortogonal a otras métricas                           |
| Rentable           | 4/4 (Excelente) | Herramientas automatizan                             |
| MEDIA              | 4.0/4           | EXCELENTE                                            |

## GRUPO 6: MÉTRICAS DE MADUREZ (IMG)

### M6.1: Índice de Madurez General (IMG)

**Definición:** Promedio de Tier madurez (1-4) de 6 funciones NIST CSF, normalizado 0-100

| Criterio PRAGMATIC | Calificación    | Evidencia                                     |
|--------------------|-----------------|-----------------------------------------------|
| Predictivo         | 4/4 (Excelente) | IMG 60+ → Incidentes reducen 50%              |
| Relevante          | 4/4 (Excelente) | KPI estratégico (C-suite, auditoría)          |
| Accionable         | 3/4 (Bueno)     | CISO define roadmap (requiere inversión)      |
| Genuino            | 2/4 (Aceptable) | Depende de autoevaluación (puede ser sesgado) |
| Significativo      | 4/4 (Excelente) | Impacta decisiones presupuestarias            |
| Preciso            | 2/4 (Aceptable) | ±10 puntos (subjektividad evaluador)          |
| Oportuno           | 3/4 (Bueno)     | Anual (evaluación requiere tiempo)            |
| Independiente      | 3/4 (Bueno)     | Agregado de 6 métricas (algo colineal)        |
| Rentable           | 2/4 (Aceptable) | Evaluación externa cara (€20-50K)             |
| <b>MEDIA</b>       | <b>3.1/4</b>    | <b>BUENO</b>                                  |

## GRUPO 7: MÉTRICAS DE ROI Y COSTES (CAsPeA)

### M7.1: Coste Total Anual CAsPeA (€)

**Definición:** Suma de salarios + beneficios de personal dedicado a ciberseguridad

| Criterio PRAGMATIC | Calificación    | Evidencia                                        |
|--------------------|-----------------|--------------------------------------------------|
| Predictivo         | 3/4 (Bueno)     | CAsPeA aumenta → Capacidades mejoran (no lineal) |
| Relevante          | 4/4 (Excelente) | CFO, Junta lo requieren                          |
| Accionable         | 4/4 (Excelente) | CISO controla (hiring, outsourcing)              |
| Genuino            | 4/4 (Excelente) | Nómina verificable                               |
| Significativo      | 4/4 (Excelente) | 60-70% presupuesto seguridad                     |
| Preciso            | 4/4 (Excelente) | ±2% (datos nómina exactos)                       |
| Oportuno           | 4/4 (Excelente) | Disponible mensual                               |
| Independiente      | 4/4 (Excelente) | No covarría spuriamente                          |
| Rentable           | 4/4 (Excelente) | Datos internos                                   |
| <b>MEDIA</b>       | <b>3.8/4</b>    | <b>EXCELENTE</b>                                 |

### M7.2: ROI de Ciberseguridad (%)

**Definición:** (Pérdida Evitada - Inversión) / Inversión × 100%

| Criterio PRAGMATIC | Calificación     | Evidencia                                                  |
|--------------------|------------------|------------------------------------------------------------|
| Predictivo         | 3/4 (Bueno)      | ROI >30% – Inversión justificada (predictivo pero ex-post) |
| Relevante          | 4/4 (Excelente)  | Lenguaje CFO                                               |
| Accionable         | 2/4 (Aceptable)  | No directamente controlable (depende incidentes)           |
| Genuino            | 2/4 (Aceptable)  | Requiere estimaciones (incidentes evitados)                |
| Significativo      | 4/4 (Excelente)  | Decisión presupuestaria depende                            |
| Preciso            | 1/4 (Deficiente) | ±50% (múltiples suposiciones)                              |
| Oportuno           | 2/4 (Aceptable)  | Anual (lag larga)                                          |
| Independiente      | 3/4 (Bueno)      | Agregado de múltiples variables                            |
| Rentable           | 2/4 (Aceptable)  | Requiere análisis complejo                                 |
| <b>MEDIA</b>       | <b>2.6/4</b>     | <b>ACEPTABLE</b>                                           |

### RESUMEN EJECUTIVO: PUNTUACIONES PRAGMATIC POR MÉTRICA

| #    | Métrica               | GRUPO            | Puntuación | Recomendación                       |
|------|-----------------------|------------------|------------|-------------------------------------|
| M2.1 | CAsPeA Total Anual    | Costes           | 3.8/4      | ✓<br>IMPLEMENTAR                    |
| M4.1 | MTTD                  | SIEM             | 3.6/4      | ✓<br>IMPLEMENTAR                    |
| M3.1 | MTTR                  | SIEM             | 3.3/4      | ✓<br>IMPLEMENTAR                    |
| M2.3 | MTTR Vulnerabilidades | Vulnerabilidades | 3.8/4      | ✓<br>IMPLEMENTAR                    |
| M5.1 | Report Rate Phishing  | Capacitación     | 4.0/4      | ✓✓ PRIORITARIO                      |
| M2.1 | Frecuencia Escaneo    | Vulnerabilidades | 3.7/4      | ✓<br>IMPLEMENTAR                    |
| M6.1 | IMG (Madurez)         | Madurez          | 3.1/4      | ✓<br>IMPLEMENTAR<br>(con auditoría) |
| M7.2 | ROI Ciberseguridad    | Costes           | 2.6/4      | ⚠ USAR CON<br>CUIDADO               |



## CRITERIOS DE SELECCIÓN DE MÉTRICAS

### Recomendación:

- **Scorecard  $\geq 3.5/4$ :** IMPLEMENTAR inmediatamente
- **Scorecard 3.0-3.5:** IMPLEMENTAR con auditoría externa (validar Genuino, Preciso)
- **Scorecard  $< 3.0$ :** USAR CON CUIDADO o COMPLEMENTAR con métrica alternativa

*Matriz PRAGMATIC Completa v2.1 para CAsPeA*